

Plano e Matriz de Segurança da API

Disciplina: Segurança na Desenvolvimento de Aplicações Web / EaD

Aluno: Arthur Lucas Dandolini

1. Matriz de Segurança da API

Para mapear os riscos da API de gestão de estoque da DDA Metalúrgica, organizamos os recursos e operações principais, identificando as ameaças mais relevantes e definindo as estratégias de prevenção.

Recurso / Operação	Ameaça / Vulnerabilidade	Possível Impacto	Controle Preventivo Adotado
Autenticação (/auth/login)	Tentativas de acesso indevido (força bruta) e interceptação de credenciais.	Acesso não autorizado ao sistema e roubo de contas de usuários.	Uso do Spring Security, tráfego via HTTPS e senhas salvas com hash BCrypt.
Cadastros (Itens e Fornecedores)	SQL Injection em campos de busca e cadastro.	Leitura, alteração ou exclusão indevida de dados no PostgreSQL/MySQL.	Uso de Spring Data JPA/Hibernate (consultas parametrizadas) e validação de DTOs.

Campos de Texto (Nomes/Descrições)	XSS (Cross-Site Scripting).	Injeção de scripts maliciosos para execução no navegador do usuário.	Sanitização das entradas no backend e tratamento de saída (<i>escaping</i>) no frontend.
Consultas e Relatórios de Estoque	Acesso sem autenticação ou por usuários não autorizados.	Exposição de dados estratégicos da empresa (saldos, custos, fornecedores).	Bloqueio de endpoints pelo Spring Security, exigindo autenticação válida.
Movimentações (Entradas e Saídas)	Alteração de parâmetros na requisição (Broken Object Level Authorization).	Lançamento de movimentações falsas ou alteração indevida de saldo de estoque.	Validação no backend com DTOs, regras de negócio e checagem de perfil (ROLE).
Exclusão e Edição de Registros	Tentativa de acesso direto por IDs (IDOR) por usuários sem permissão.	Apagamento indevido de histórico ou alteração de cadastros críticos.	Restrição de rotas no Spring Security usando <code>@PreAuthorize("hasRole('ADMIN')")</code> .
Endpoints REST Gerais	CSRF (Cross-Site Request Forgery).	Execução de ações indesejadas em nome de um usuário autenticado.	Adequação da proteção CSRF ao modelo de autenticação <i>stateless</i> da API.

Endpoints REST Gerais	CORS mal configurado.	Requisições maliciosas vindas de outros domínios na web.	Configuração do CorsConfigurationSource liberando apenas a origem do frontend.
Geral / Dados de Saída	Mass Assignment / Exposição excessiva de dados.	Vazamento de dados sensíveis ou internos que não deveriam ser retornados.	Uso estrito de DTOs para mapear apenas os campos necessários na resposta.
Histórico Operacional	Falta de rastreabilidade das ações no estoque.	Impossibilidade de identificar quem realizou uma movimentação incorreta.	Logs e tabela de auditoria com ID do usuário, tipo de operação e <i>timestamp</i> .

2. Plano de Segurança da API

2.1 Autenticação

A autenticação da API será gerenciada através do **Spring Security**.

- O usuário enviará suas credenciais na rota de login e, após a validação, receberá a autorização para acessar os endpoints permitidos ao seu perfil.
- As senhas dos usuários **nunca** serão salvas em texto puro no banco de dados. Utilizaremos a classe BCryptPasswordEncoder para criptografar as senhas antes do salvamento.
- Todas as requisições entre frontend e backend trafegarão via **HTTPS**.

2.2 Divisão de Recursos (Públicos x Protegidos)

- **Recurso Público:** O único endpoint liberado sem autenticação será o de login (POST /api/v1/auth/login).
- **Recursos Protegidos:** Todos os demais endpoints do sistema exigirão autenticação obrigatória:
 - Consultas e cadastros de itens e fornecedores;
 - Registros de entradas e saídas do estoque;
 - Consultas de saldo, estoque mínimo e alertas de reposição;

- Emissão de relatórios e histórico de movimentações;
- Gerenciamento de contas de usuário.

3. Definição de Perfis e Permissões de Acesso

Definimos dois perfis de acesso (Roles) para atender à rotina operacional da metalúrgica:

1. **ROLE_USER (Operador de Estoque):**

- **Pode realizar:** Login, consultas de produtos, fornecedores, estoques e alertas, além de registrar as entradas e saídas do dia a dia e visualizar os relatórios.
- **Não pode realizar:** Cadastrar novos produtos/fornecedores, alterar ou excluir itens existentes e gerenciar outros usuários.

2. **ROLE_ADMIN (Administrador do Sistema):**

- **Pode realizar:** Todas as operações do perfil ROLE_USER mais as rotas administrativas: cadastrar, editar e excluir itens/fornecedores, gerenciar permissões e acessar todo o histórico do sistema.

4. Tabela de Permissões por Recurso

Recurso / Operação	Endpoint / Operação	Público	Operador (ROLE_USER)	Administrador (ROLE_ADMIN)
Autenticação	Login (POST /auth/login)	Sim	Sim	Sim
Consulta de Itens	GET /api/itens	Não	Sim	Sim
Cadastro de Item	POST /api/itens	Não	Não	Sim
Edição / Exclusão de Item	PUT / DELETE /api/itens/{id}	Não	Não	Sim

Consulta de Fornecedores	GET /api/fornecedores	Não	Sim	Sim
Cadastro / Edição de Fornecedor	POST / PUT /api/fornecedores	Não	Não	Sim
Consultas de Estoque e Alertas	GET /api/estoque/*	Não	Sim	Sim
Registro de Entrada / Saída	POST /api/movimentacoes/*	Não	Sim	Sim
Relatórios e Histórico	GET /api/relatorios/*	Não	Sim	Sim
Gestão de Usuários	GET / POST /api/usuarios	Não	Não	Sim

5. Decisões Técnicas de Proteção

- **Controle de Autorização:** A validação será feita diretamente nos métodos dos controllers ou no SecurityFilterChain, garantindo que o perfil do usuário seja checado antes de processar qualquer lógica.
- **Proteção contra SQL Injection:** Utilizaremos métodos do Spring Data JPA e consultas com @Query parametrizadas, evitando concatenação direta de strings na montagem do SQL.
- **Configuração de CORS:** Restringiremos as origens permitidas via CorsConfiguration. Em desenvolvimento liberaremos a porta do frontend local (ex: http://localhost:3000) e em produção apenas o domínio oficial da empresa.
- **Validação de Dados:** Usaremos anotações do Jakarta Bean Validation (@NotNull, @Positive, @Size) nos DTOs de entrada para impedir que requisições com dados inconsistentes cheguem ao banco de dados.
- **Rastreabilidade e Auditoria:** Toda movimentação de entrada/saída gravará no banco o ID do usuário responsável, garantindo a rastreabilidade exigida pelo projeto.